

CAMS DOMAIN C

BUILDING AN AML/AFC COMPLIANCE PROGRAM

HARD QUESTIONS & EXAM TRAPS 30% of Exam

Core Pillars ù Three Lines of Defense ù Risk Appetite Statement
EWRA ù Risk-Based Approach ù Policies/Standards/Procedures
KYC/CDD/EDD ù Transaction Monitoring ù KPIs/KRIs
Board Reporting ù Controls Lifecycle ù Risk Assessments

Core Pillars The Foundation Trap

The Hard Question CAMS Exam Favorite

What are the core pillars of an effective AML/AFC compliance program?

✓ **CORRECT:** 1. Risk Assessment. 2. Internal Controls. 3. Independent Testing. 4. Training. 5. Designated Compliance Officer.

Natural Explanation Why You Got This Wrong

- ▶ Only risk assessment and monitoring **NO**. There are **5 core pillars**, not just 2.
- ▶ **US BSA Requirement:** Every AML program must have:
 1. **Risk Assessment** Understand your risks
 2. **Internal Controls** Policies, procedures, systems
 3. **Independent Testing** Audit the program
 4. **Training** Educate employees
 5. **Designated Compliance Officer (MLRO)** Responsible person
- ▶ **FATF Rec 18:** Requires internal controls, independent audit, and compliance officer.
- ▶ **Key principle:** All 5 pillars are **required**. Missing any one = non-compliant.

REMEMBER: Key Rule: 5 pillars = Risk Assessment + Internal Controls + Independent Testing + Training + Compliance Officer.

Three Lines of Defense The Role Trap

The Hard Question CAMS Exam Favorite

Which correctly describes the roles and responsibilities of the three lines of defense?

✓ **CORRECT: 1st Line: Business units manage risk. 2nd Line: Compliance oversees. 3rd Line: Internal Audit assures.**

Natural Explanation Why You Got This Wrong

- ▶ Compliance is the first line **NO**. Compliance is **second line**.
- ▶ Internal Audit manages risk **NO**. Audit **assesses**, doesn't manage.
- ▶ **First Line:** Business units (operations, sales, front office). They **own and manage** risk.
- ▶ **Second Line:** Compliance, risk management, MLRO. They **oversee and challenge** the first line.
- ▶ **Third Line:** Internal Audit. They provide **independent assurance**.
- ▶ **Key principle:** 1st = **do**. 2nd = **oversee**. 3rd = **audit**.

REMEMBER: Key Rule: 1st = Operations. 2nd = Compliance. 3rd = Audit.

MLRO/BSA Officer The Responsibility Trap

The Hard Question CAMS Exam Favorite

What is the primary responsibility of the MLRO/BSA Officer?

✓ **CORRECT:** Oversee the AML program and file suspicious transaction reports with the FIU.

Natural Explanation Why You Got This Wrong

- ▶ Conduct all investigations personally **NO**. The MLRO **oversees**, doesn't do all the work.
- ▶ Make all compliance decisions alone **NO**. The MLRO has authority but works with committees.
- ▶ **MLRO (UK/EU) / BSA Officer (US):**
 - ▶ Designated person responsible for AML compliance
 - ▶ Must have **authority and resources**
 - ▶ Files SARs/STRs with the FIU
 - ▶ Reports to senior management and board
- ▶ **Key principle:** The MLRO is the **point of contact** for regulators and FIUs.

REMEMBER: Key Rule: MLRO = oversight + SAR/STR filing.

Risk Appetite Statement The Purpose Trap

The Hard Question CAMS Exam Favorite

What is the purpose of a Risk Appetite Statement (RAS)?

✓ **CORRECT:** To define how much risk the institution is willing to accept and guide control implementation.

Natural Explanation Why You Got This Wrong

- ▶ To eliminate all risk **NO**. Risk cannot be eliminated, only managed.
- ▶ To set the budget for compliance **NO**. It's about **risk tolerance**, not budget.
- ▶ RAS defines:
 - ▶ What risks are **acceptable**
 - ▶ What risks are **unacceptable**
 - ▶ How to **measure** risk
 - ▶ When to **escalate**
- ▶ **Key principle:** RAS must be **communicated** to all employees and **implemented** through controls.

REMEMBER: Key Rule: RAS = acceptable risk level + guide for controls.

EWRA Inherent vs Residual Risk Trap

The Hard Question CAMS Exam Favorite

What is the difference between inherent risk and residual risk in an EWRA?

✓ **CORRECT:** Inherent risk = risk before controls. Residual risk = risk after controls.

Natural Explanation Why You Got This Wrong

- ▶ Inherent risk is always higher **NO**. It's **before** controls, so it's usually higher.
- ▶ Residual risk is the only risk that matters **NO**. Both matter.
- ▶ **Inherent Risk:** Risk without any controls (e.g., all cash transactions are high risk).
- ▶ **Control Effectiveness:** How well controls reduce risk (e.g., CDD, monitoring).
- ▶ **Residual Risk:** Risk that remains after controls (e.g., cash transactions with controls are medium risk).
- ▶ **Key principle:** Controls must reduce residual risk to **within risk appetite**.

REMEMBER: Key Rule: Inherent = **before** controls. Residual = **after** controls.

Risk-Based Approach The De-Risking Trap

The Hard Question CAMS Exam Favorite

What does the risk-based approach require in terms of controls?

✓ **CORRECT:** Building controls commensurate with the identified risks.

Natural Explanation Why You Got This Wrong

- ▶ Applying the same controls to all customers **NO.** That's **prescriptive**, not risk-based.
- ▶ Declining all high-risk customers **NO.** That's **de-risking**, which FATF discourages.
- ▶ Risk-based approach means:
 - ▶ High risk = more controls (EDD, monitoring)
 - ▶ Medium risk = standard controls (CDD)
 - ▶ Low risk = fewer controls (SDD)
- ▶ Key principle: Controls must be **proportionate** to risk. NOT **one-size-fits-all**.

REMEMBER: Key Rule: Risk-based = **proportionate** controls. NOT de-risking.

Policies/Standards/Procedures The Hierarchy Trap

The Hard Question CAMS Exam Favorite

What is the difference between policies, standards, and procedures?

✓ **CORRECT:** Policies = WHAT and WHY. Standards = MANDATORY REQUIREMENTS. Procedures = HOW.

Natural Explanation Why You Got This Wrong

- ▶ They are all the same thing **NO**. Different levels of detail.
- ▶ Policies:
 - ▶ High-level statements of intent
 - ▶ Example: "We will comply with all AML laws"
 - ▶ **WHAT** and **WHY**
- ▶ Standards:
 - ▶ Mandatory requirements
 - ▶ Example: "All customers must be risk-rated"
 - ▶ **MANDATORY REQUIREMENTS**
- ▶ Procedures:
 - ▶ Step-by-step instructions
 - ▶ Example: "Step 1: Collect ID. Step 2: Verify..."
 - ▶ **HOW**
- ▶ **Key principle:** Policies set direction; standards set rules; procedures show how to comply.

REMEMBER: Key Rule: Policies = WHAT/WHY. Standards = REQUIREMENTS. Procedures = HOW.

Horizon Scanning The Emerging Risks Trap

The Hard Question CAMS Exam Favorite

What is horizon scanning in the context of AML policies?

✓ **CORRECT:** Identifying emerging risks and regulatory changes that could affect the AML program.

Natural Explanation Why You Got This Wrong

- ▶ Reviewing past incidents only **NO**. Horizon scanning is **future-oriented**.
- ▶ Checking current compliance **NO**. That's monitoring, not horizon scanning.
- ▶ Horizon scanning includes:
 - ▶ Regulatory changes (new laws, guidance)
 - ▶ Emerging risks (crypto, AI, new ML methods)
 - ▶ Industry best practices (Wolfsberg, FATF updates)
- ▶ Key principle: Policies must be **forward-looking**, not just reactive.

REMEMBER: Key Rule: Horizon scanning = future risks + regulatory changes.

KYC/CDD/EDD The Timing Trap

The Hard Question CAMS Exam Favorite

When must CDD be performed?

✓ **CORRECT:** Before establishing a relationship, before occasional transactions, when suspicion arises, or when data is doubted.

Natural Explanation Why You Got This Wrong

- ▶ Only at account opening **NO**. Also for occasional transactions.
- ▶ Only when required by regulator **NO**. Must be proactive.
- ▶ CDD Timing:
 - ▶ **Before** establishing relationship (always)
 - ▶ **Before** occasional transaction (above threshold)
 - ▶ **When** suspicion arises (overrides SDD)
 - ▶ **When** doubt about data (re-verify)
- ▶ **Key principle:** CDD is **ongoing**, not one-time.

REMEMBER: Key Rule: CDD = before relationship + before occasional + when suspicious + when doubted.

The Hard Question CAMS Exam Favorite

What is the difference between Source of Wealth and Source of Funds?

✓ **CORRECT: SOW = overall wealth accumulation. SOF = specific funds for the transaction.**

Natural Explanation Why You Got This Wrong

- ▶ They are the same thing **NO**. Different concepts.
- ▶ Source of Wealth (SOW):
 - ▶ *How* did you get your money?
 - ▶ Overall wealth picture
 - ▶ Inheritance, business profits, investments
- ▶ Source of Funds (SOF):
 - ▶ *Where* did this specific money come from?
 - ▶ Sale of property, salary, business sale
- ▶ Key principle: BOTH required for EDD (PEPs, high-risk).

REMEMBER: Key Rule: SOW = overall wealth. SOF = specific funds. Both required.

Customer Risk Assessment The Updating Trap

The Hard Question CAMS Exam Favorite

When should a customer risk assessment be updated?

✓ **CORRECT:** When new information emerges, when risk profile changes, or at regular intervals.

Natural Explanation Why You Got This Wrong

- ▶ Only at onboarding **NO.** Risk is dynamic.
- ▶ Only when regulators ask **NO.** Must be proactive.
- ▶ Update triggers:
 - ▶ New transaction patterns
 - ▶ PEP status changes
 - ▶ Adverse media hits
 - ▶ Jurisdictional risk changes
 - ▶ Regular reviews (e.g., annually for high-risk)
- ▶ Key principle: Risk assessments must be **dynamic** and **ongoing**.

REMEMBER: Key Rule: Customer risk = **dynamic**. Update when risk changes.

Transaction Monitoring The Scenario Trap

The Hard Question CAMS Exam Favorite

What is the purpose of transaction monitoring scenarios?

✓ **CORRECT:** To detect patterns of suspicious activity based on identified money laundering typologies.

Natural Explanation Why You Got This Wrong

- ▶ To catch all suspicious transactions **NO**. Scenarios are **targeted**, not comprehensive.
- ▶ To replace human judgment **NO**. Scenarios generate alerts for human review.
- ▶ Scenarios:
 - ▶ Structured transactions
 - ▶ Round-trip transactions
 - ▶ High-value transfers
 - ▶ Unusual jurisdictions
- ▶ **Key principle:** Scenarios must be **updated** as typologies evolve.

REMEMBER: Key Rule: Transaction monitoring = **targeted scenarios** + **human review**.

KPIs vs KRIs The Performance Trap

The Hard Question CAMS Exam Favorite

What is the difference between KPIs and KRIs?

✓ **CORRECT:** KPIs measure performance. KRIs measure risk.

Natural Explanation Why You Got This Wrong

- ▶ They are the same thing **NO**. Different purposes.
- ▶ **Key Performance Indicators (KPIs):**
 - ▶ How well is the program working?
 - ▶ Example: # of SARs filed,
- ▶ **Key Risk Indicators (KRIs):**
 - ▶ What is the risk exposure?
 - ▶ Example: # of high-risk customers,
- ▶ **Key principle:** Boards need BOTH to make decisions.

REMEMBER: Key Rule: KPI = performance. KRI = risk.

Board Reporting The Content Trap

The Hard Question CAMS Exam Favorite

What should board reporting on AFC include?

✓ **CORRECT:** KPIs, KRIs, regulatory interactions, emerging risks, and control effectiveness.

Natural Explanation Why You Got This Wrong

- ▶ Only financial metrics **NO**. AFC reporting is about **risk**, not profit.
- ▶ Only regulatory findings **NO**. Board needs **forward-looking** info too.
- ▶ Board reports should include:
 - ▶ **KPIs/KRIs:** Performance and risk metrics
 - ▶ **Regulatory interactions:** What did regulators say?
 - ▶ **Emerging risks:** What's coming?
 - ▶ **Control effectiveness:** Are controls working?
- ▶ **Key principle:** Board needs a **complete picture** of risk and performance.

REMEMBER: Key Rule: Board reports = KPIs + KRIs + regulatory + emerging + controls.

FC Reporting The Jurisdictional Trap

The Hard Question CAMS Exam Favorite

What must institutions consider about financial crime reporting across jurisdictions?

✓ **CORRECT:** Reporting requirements differ by jurisdiction and must be met separately.

Natural Explanation Why You Got This Wrong

- ▶ One global report is enough **NO**. Each jurisdiction has its own rules.
- ▶ Only home country reporting matters **NO**. Host countries also require reporting.
- ▶ Examples of differences:
 - ▶ US: SARs to FinCEN
 - ▶ UK: STRs to NCA
 - ▶ EU: STRs to national FIU
- ▶ **Key principle:** Must comply with **all** jurisdictions where you operate.

REMEMBER: Key Rule: Reporting = **jurisdiction-specific**. Must comply with all.

Risk Types The Non-Financial Risk Trap

The Hard Question CAMS Exam Favorite

What types of risk must be managed in an AML program?

✓ **CORRECT:** Financial risk, operational risk, non-financial risk, and reputational risk.

Natural Explanation Why You Got This Wrong

- ▶ Only financial risk **NO**. AML is about **multiple risk types**.
- ▶ **Financial Risk:** Loss from financial crime
- ▶ **Operational Risk:** Failure of processes, systems, people
- ▶ **Non-Financial Risk:** Compliance, legal, conduct risk
- ▶ **Reputational Risk:** Damage to reputation from AML failures
- ▶ **Key principle:** All risk types are **interconnected** in AML.

REMEMBER: Key Rule: AML risk = financial + operational + non-financial + reputational.

Controls Lifecycle The Onboarding to Exit Trap

The Hard Question CAMS Exam Favorite

When should AML controls be applied?

✓ **CORRECT:** At onboarding, throughout the customer lifecycle, and at exit.

Natural Explanation Why You Got This Wrong

- ▶ Only at onboarding **NO**. Controls are **ongoing**.
- ▶ Only when suspicious **NO**. Controls are **continuous**.
- ▶ Controls Lifecycle:
 - ▶ **Onboarding:** CDD, sanctions screening, risk rating
 - ▶ **Ongoing:** Transaction monitoring, periodic reviews, trigger-based updates
 - ▶ **Exit:** Account closure, SAR filing, liaison with FIUs
- ▶ Key principle: Controls are **continuous**, not one-time.

REMEMBER: Key Rule: Controls = onboarding + ongoing + exit.

Employee Due Diligence The Screening Trap

The Hard Question CAMS Exam Favorite

What does employee due diligence involve?

✓ **CORRECT:** Screening employees against sanctions, PEP lists, and for criminal history.

Natural Explanation Why You Got This Wrong

- ▶ Only background checks **NO**. More than just criminal checks.
- ▶ Only for senior management **NO**. All employees should be screened.
- ▶ Employee Due Diligence includes:
 - ▶ Sanctions screening
 - ▶ PEP screening
 - ▶ Criminal background checks
 - ▶ Conflict of interest checks
- ▶ Key principle: Employees can be a risk vector screen them.

REMEMBER: Key Rule: Employee DD = sanctions + PEP + criminal + conflict checks.

Risk Assessment Types The Comprehensive Trap

The Hard Question CAMS Exam Favorite

What types of risk assessments are needed in an AML program?

✓ **CORRECT: National Risk Assessment, Entity-wide Risk Assessment, and Customer Risk Assessment.**

Natural Explanation Why You Got This Wrong

- ▶ Only customer risk assessment **NO**. Need **multiple layers**.
- ▶ Types of Risk Assessments:
 - ▶ **National Risk Assessment (NRA)**: Country-level risk
 - ▶ **Entity-Wide Risk Assessment (EWRA)**: Institution-level risk
 - ▶ **Customer Risk Assessment**: Individual customer risk
 - ▶ **Product Risk Assessment**: Product-specific risk
 - ▶ **Jurisdictional Risk Assessment**: Country risk
- ▶ Key principle: Risk assessment must be **multi-layered** and **comprehensive**.

REMEMBER: Key Rule: Risk assessments = NRA + EWRA + customer + product + jurisdictional.

Domain C Critical Exam Traps

Most Common Traps Domain C

1. **5 Pillars:** Risk Assessment + Internal Controls + Independent Testing + Training + Compliance Officer.
2. **Three Lines:** 1st = Operations. 2nd = Compliance. 3rd = Audit.
3. **MLRO: Oversight + SAR/STR filing.** NOT doing all investigations.
4. **RAS:** Defines **acceptable risk** and guides controls. NOT eliminating risk.
5. **EWRA:** Inherent = **before** controls. Residual = **after** controls.
6. **Risk-Based: Proportionate controls.** NOT de-risking.
7. **Policies/Standards/Procedures:** Policies = WHAT/WHY. Standards = REQUIREMENTS. Procedures = HOW.
8. **Horizon Scanning:** Future risks + **regulatory changes**. NOT past incidents.
9. **CDD Timing:** Before relationship + before occasional + **when suspicious** + **when doubted**.
10. **SOW vs SOF:** SOW = overall wealth. SOF = **specific funds**. Both required.
11. **Customer Risk: Dynamic.** Update when risk changes.
12. **Transaction Monitoring: Targeted scenarios + human review.**
13. **KPIs vs KRIs:** KPI = performance. KRI = risk.
14. **Board Reporting:** KPIs + KRIs + regulatory + emerging + controls.
15. **Reporting: Jurisdiction-specific.** Must comply with all.
16. **Risk Types:** Financial + operational + non-financial + reputational.
17. **Controls Lifecycle:** Onboarding + ongoing + exit.
18. **Employee DD:** Sanctions + PEP + criminal + conflict.
19. **Risk Assessments:** NRA + EWRA + customer + product + jurisdictional.

REMEMBER: Final Rule: Domain C = **program design, governance, and controls**. Understand the **structure**.

Domain C Complete

Building an AML/AFC Compliance Program

Core Pillars ð Three Lines of Defense ð Risk Appetite Statement
EWRA ð Risk-Based Approach ð Policies/Standards/Procedures
KYC/CDD/EDD ð Transaction Monitoring ð KPIs/KRIs
Board Reporting ð Controls Lifecycle ð Risk Assessments

All traps explained. All concepts covered. Ready for the exam.